

Кейс: «Чёрный бармен» — воспроизведение референсного API

AntiHack 2026 | 25–26 апреля, Уфа — цель: клонировать API референса с точным совпадением ответов, кодов состояния и логики. Стек реализации: Java + Spring Boot.



Api Entbnonts

► Api Bngtofonlt

▼ P Sopelniapt



Задача — суть и критерии успеха

- Имеется референсный API: <https://bar.antihype.lol> — документация частичная.
- Нужно методом черного ящика воспроизвести поведение: HTTP-коды, JSON-поля, заголовки и логика.
- Критерий: полное совпадение ответов при идентичных запросах (включая ошибочные сценарии).

Обязательные эндпоинты



POST /register

Регистрация — возвращает Bearer token и начальные поля профиля.



POST /reset

Сброс аккаунта — очищает баланс, историю, настройку бармена



GET /menu

Возвращает меню с учётом заголовка X-Time



POST /order, POST /mix

Заказ по имени и смешивание по ингредиентам — проверка баланса, валидация рецептов.



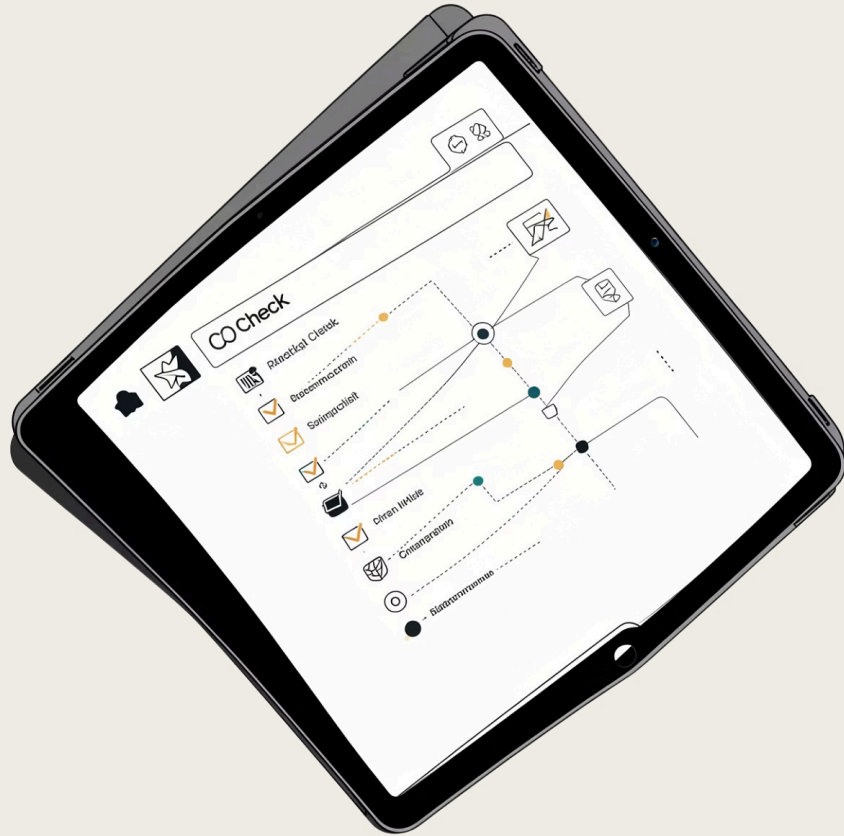
Баланс и история

GET /balance, GET /history — подробные записи с type: order|mix, метками времени и эффектами.



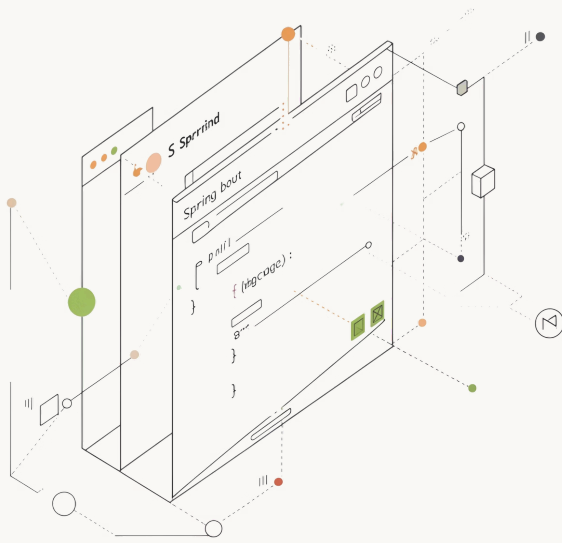
GET /profile, POST /tip

Профиль с рангом и статистикой; чаевые модифицируют баланс и настройку бармена.



Недокументированные правила — что нужно было обнаружить

1. `mood_level` — динамический параметр бармена, меняется от действий клиента (чаевые, чрезмерные заказы, секреты).
2. Ранг — считается по числу уникальных выпитых напитков (уникальность по имени/рецепту).
3. Время (X-Time) влияет на доступность пунктов меню и на скрытые рецепты.
4. Промокоды: разные эффекты.
5. Бармен может временно «закрыть бар».



Решения и инженерные детали

Ключевые элементы архитектуры:

- Контроллеры для каждого эндпоинта — строгое соответствие HTTP-кодам и схемам JSON.
- Сервисный слой эмитирует состояние бармена.
- Хранилище.
- Тесты: контрактные интеграционные тесты, воспроизводящие последовательности запросов референса.

Тестирование точного совпадения — методика

Подход черного ящика и контроль соответствия:

1. Запись трафика

Снятие запросов/ответов с референса — заголовки, тело, коды.

2. Реплей и валидация

Повторяем запросы к локальному клону, сравниваем точные JSON-деревья и статусы.

3. Вариантные сценарии

Негативные тесты, граничные значения, конкурентные запросы, смена X-Time.

Api Contract Testing With

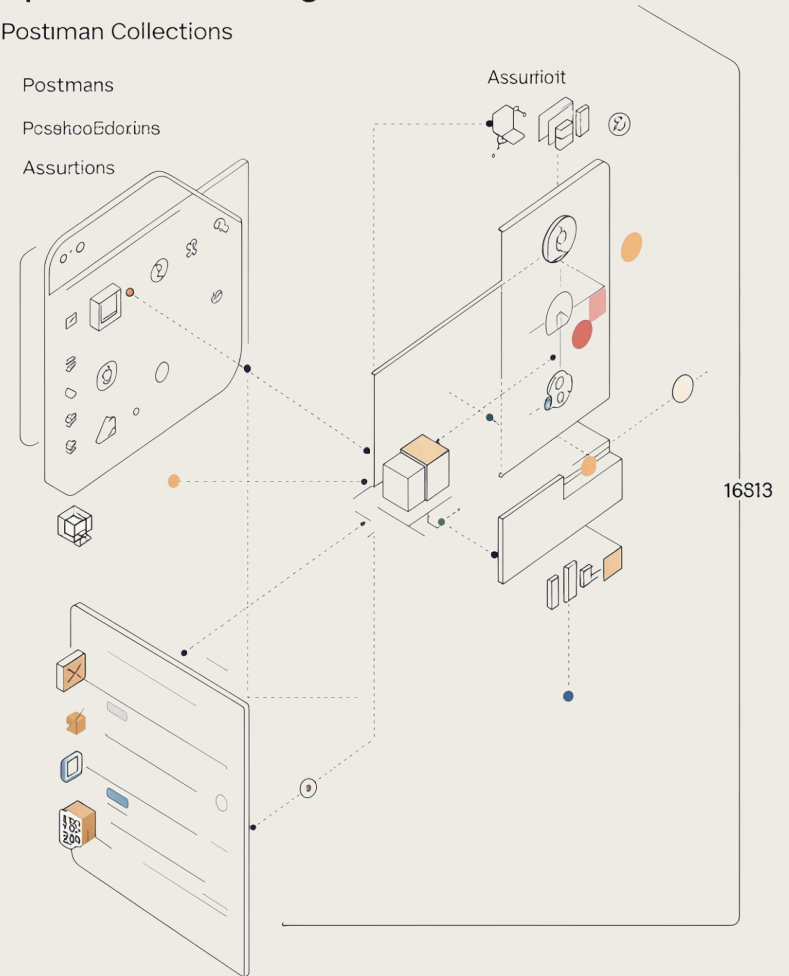
Postman Collections

Postmans

PostmanEtorins

Assurtions

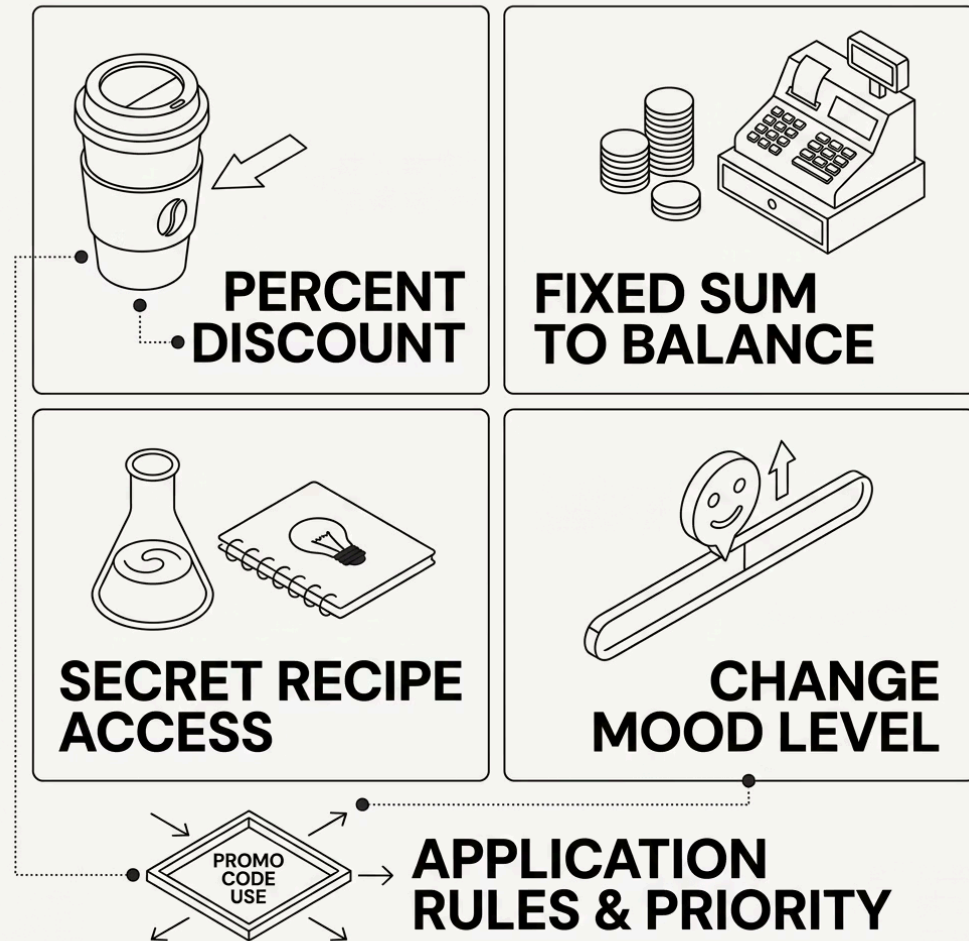
Assurtioit



Промокоды, скрытые эндпоинты и пасхалки

Наблюдения и поведение:

- Заказы меняют mood_level и могут открывать редкие рецепты или особые статусы в профиле.
- Время влияет на доступность
- Есть скрытые рецепты
- Бармен может закрыть бар



Telegram-бот — интеграция для удобной проверки

Бот повторяет ключевые команды и служит тестовым интерфейсом для быстрой валидации поведения API:



**/start, /menu,
/balance**

Быстрый доступ к
состоянию и меню —
полезно для
оперативной проверки
X-Time и секретов.



/order, /mix

Отправка заказов и
миксов — возвращает
те же ответы, что и API
(ошибки, баланс).



/reset, /profile, /tip

Полный сброс и
манипуляция
балансом/mood для
воспроизведения
сценариев референса.

Спасибо за внимание

